

[doc. web n. 10070832]  
Provision of September 12, 2024  
Register of Provisions  
No. 552 of September 12, 2024

## THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting held today, attended by  
Prof. Pasquale Stanzione, president, Prof.  
Ginevra Cerrina Feroni, vice president, Dr.  
Agostino Ghiglia and Attorney Guido Scorza, members, and  
Secretary General Fabio Mattei;

HAVING REGARD to Regulation (EU) 2016/679 of the European Parliament  
and of the Council, of April 27, 2016 (hereinafter "Regulation");

HAVING REGARD to Legislative Decree No. 196 of June 30, 2003 (Code regarding the protection of  
personal data, hereinafter "Code") as amended by Legislative Decree No. 101 of August 10, 2018,  
containing "Provisions for the adaptation of national legislation to the provisions of Regulation (EU)  
2016/679";

HAVING REGARD to the complaint submitted to the Guarantor pursuant to  
Article 77 of the Regulation on February 4, 2023, by Mr. XX, who alleged a  
presumed violation of the regulatory framework regarding the protection of personal data, specifically  
referring to a lack of response provided by Medic4All Italia S.r.l. regarding the request to exercise  
rights made by the complainant, pursuant to Article 15 of the Regulation, on January 3, 2023, against  
the same;

HAVING EXAMINED the documentation on record;

HAVING REGARD to the observations made by the Secretary General pursuant to Article 15 of the  
Guarantor's Regulation No. 1/2000;

REPORTING by Dr. Agostino Ghiglia;

## WHEREAS

1. The complaint and the investigative activity.

With a complaint submitted to this Authority, pursuant to Article 77 of Regulation EU 679/2016  
(hereinafter "Regulation"), on February 4, 2023, Mr. XX complained that he had submitted, on January  
3, 2023, a request for access pursuant to Article 15 of the Regulation against Medic4All Italia S.r.l.  
(hereinafter "Company") and had not received a response regarding it.

Following the transmission to the Company, with communication from the Office dated February 23,  
2023, of the invitation to comply with the aforementioned request, Medic4All Italia S.r.l. initially stated  
that there were no data related to the complainant in its archives (see communication of March 19,  
2023).

Subsequently, in response to some observations made on the matter by Mr. XX with a note dated  
March 19, 2023—also containing a copy of the documentation certifying the requests sent by him to  
the Company regarding various healthcare services previously provided by Medic4All Italia S.r.l.—the  
Company, in addition to the above, provided further clarifications to the complainant, and  
simultaneously to the Authority, regarding the processing of data concerning him. In particular, the  
Company specified that it "manages on behalf of third parties the liquidation and verification  
procedures in the event of claims" and that such "management takes place on systems of the third  
party and the archives are held by the third party [in this case Intesa Sanpaolo Assicura S.p.A.]" (see  
communication of March 25, 2023).

In light of the above statements and the observations made by the complainant regarding this with  
communication dated March 25, 2023, the Office, on May 2, 2023, made a request for information,  
pursuant to Article 157 of the Code, in order to acquire useful elements aimed at identifying the data

processing carried out by Medic4All Italia S.r.l. with particular reference to the role played by it, in this case, regarding the regulations on the protection of personal data and the possible designation of the same as a data processor, pursuant to Article 28 of the Regulation, by the data controller of the contested data, namely Intesa Sanpaolo Assicura S.p.A.

It was established that the aforementioned request, although duly notified to Medic4All Italia S.r.l. via certified email, remained unanswered (see related delivery certificate of the certified email, dated May 2, 2023), the Authority, pursuant to Article 166, paragraph 5 of the Code, notified the violation of Article 157 of the Code (Article 166, paragraph 2 of the Code), and simultaneously acquired, from the Company, the requested information with the Guarantor's note of May 2, 2023.

Following the investigations carried out, the Company, on October 2, 2023, sent further documentation to the Guarantor.

From the examination of the statements made during the inspections and the documentation subsequently transmitted to them, it particularly emerged that:

the Company carries out "the management of health claims, as a run-off activity, for the sole client Intesa San Paolo Assicura S.p.A. and also provides telemedicine services to the beneficiaries of third-party companies" (see minutes of September 21, 2023, p. 2);

with Intesa San Paolo Assicura S.p.A. "there is a contract for the provision of services and claims management signed on January 1, 2014" (see minutes of September 21, 2023, p. 2 and subsequent note, containing a copy of this contract, dated October 2, 2023);

the Company "processes the health data of the beneficiaries of (...) Intesa San Paolo Assicura S.p.A." and has been designated by the latter as the data processor, pursuant to Article 28 of the Regulation, with a designation act dated June 11, 2018 (see minutes...

of September 21, 2023, p. 2);

in the aforementioned appointment deed, it is established that the Company, as the data processor on behalf of Intesa San Paolo Assicura S.p.A., must "collaborate with the data controller – with appropriate technical and organizational measures – so that [the latter] can provide the necessary feedback to requests from data subjects regarding the exercise of the rights under Articles 15-22 of the GDPR; for this purpose, the Processor must inform the data controller within three (3) working days of any requests that may be received from data subjects aimed at exercising the rights referred to in the aforementioned articles, and provide the data controller with everything necessary for the relevant responses, and any measures to be taken in this regard" (see Annex 2 to the minutes of September 21, 2023, containing the appointment deed of June 11, 2018, see in particular letter k);

with reference to the violation of Article 157 of the Code as a consequence of the failure to respond to the request for information sent by the Guarantor on May 2, 2023, such request "went unread due to organizational issues, which have now been resolved" (see communication of October 2, 2023);

following the checks carried out by this Authority, a series of technical-organizational measures have been adopted aimed at implementing "procedures and safeguards to further ensure the privacy of any visitors to the site or assisted and insured individuals," such as, for example, the verification, as well as the provision for monitoring at least twice a day, of the email box designated for communications with users (see communication of October 2, 2023).

In light of the elements overall acquired during the investigation, with communication dated December 7, 2023, the Office proceeded to notify Medical4All Italia S.r.l. of the initiation of proceedings for the adoption of measures pursuant to Articles 58, paragraph 2, and 83 of the Regulation in relation to the violation of Article 28, paragraph 3, letter e) of the Regulation; this in accordance with the provisions of Article 166, paragraph 5, of the Code.

Lastly, it is noted that the Company, following the notification of both acts initiating the aforementioned sanctioning procedure, did not avail itself of the rights provided for by Article 18 of Law No. 689/1981, not sending any defensive writings nor requesting to be heard.

## 2. The outcome of the investigation.

First and foremost, it is highlighted that, unless the fact constitutes a more serious offense, anyone who, in a proceeding before the Guarantor, falsely declares or certifies news or circumstances or produces false acts or documents is liable under Article 168 of the Code "Falsehood in declarations to the Guarantor and interruption of the execution of the tasks or the exercise of the powers of the

Guarantor.”

Having duly stated this, at the conclusion of the investigative activity and the subsequent evaluations carried out by the Authority in this regard, it was first ascertained that the Company, in the context of the provision of services rendered to the assisted individuals of third-party companies, has carried out, in the case in question, as the data processor pursuant to Article 28 of the Regulation, operations of processing personal data relating to the data subject on behalf of Intesa San Paolo Assicura S.p.A. Specifically, as further detailed below, based on the elements acquired during the on-site inspections and the examination of the documentation and additional elements subsequently transmitted to the Guarantor, it was established that Medical4All Italia S.r.l. did not act in this context in accordance with the provisions of the current legislation on personal data protection (Regulation and Code). In this regard, the following observations are made.

2.1. Violation of the obligations of the Data Processor under Article 28, paragraph 3 of the Regulation. Preliminarily, it is represented that – given the elements acquired and the facts emerged following the investigative activity – it is established that Medical4All Italia S.r.l. has assumed the role of processor pursuant to Article 28 of the Regulation with respect to the data relating to the complainant subject to processing in the case in question (see above, paragraph 1).

Having stated this, with specific reference to the request made by the complainant to the Company on January 3, 2023, and the current regulatory framework regarding personal data protection concerning the exercise of rights by the data subject, it is noted that under Article 15, paragraph 1, of the Regulation, “the data subject has the right to obtain from the data controller confirmation as to whether or not personal data concerning him or her is being processed and, if so, to obtain access to the personal data and [certain] information” indicated in that provision.

The recipient of the request made pursuant to Article 15 of the Regulation is therefore the data controller, who is indeed required, as established in Article 12, paragraph 3 of the Regulation, to provide “the data subject with information regarding the action taken concerning [the same] without undue delay and, in any event, no later than one month from [its] receipt.”

Notwithstanding the above, it is worth highlighting that although the data processor is not the entity responsible, under the legislation on personal data protection, for directly responding to the aforementioned requests (see above), Article 28, paragraph 3, letter e) of the Regulation nevertheless provides that it must assist “the data controller with appropriate technical and organizational measures, insofar as this is possible, in order to meet the data controller's obligation to treatment of following up on requests for the exercise of the rights of the data subject referred to in Chapter III” (see regarding the European Data Protection Board - EDPB, “Guidelines 07/2020 on the concepts of controller and processor under the GDPR”, adopted on July 7, 2021, par. 1.3.5). All this is based on the contract (or other legal act), concluded in writing, which regulates, pursuant to Article 28 of the Regulation, the relationship established with the controller also concerning this specific aspect. This is an act that, in addition to mutually binding the parties, contains, as established in Article 28, par. 3 of the Regulation, the instructions that the controller gives to the processor also regarding the measures that the latter is required to implement in order to allow the controller to follow up on the requests for the exercise of rights made by the data subjects referred to in Chapter III of the Regulation. In fact, “the details regarding the assistance that the processor is required to provide [with respect to the above requests] should be provided in the [above-mentioned] contract or in an annex to it” (see on this point, EDPB, Guidelines 07/2020, cited, par. 1.3.5).

In the specific case, it has been noted that Intesa San Paolo Assicura S.p.A., as the data controller, provided the aforementioned instructions to Medical4All S.r.l., within the appointment act of June 11, 2018, explicitly stating, in point 2, k) of the same, that the processor is required to “collaborate with the Controller – with appropriate technical and organizational measures – so that it can provide the necessary feedback to the requests of the data subjects regarding the exercise of the rights referred to in Articles 15-22 of the GDPR; for this purpose, the Processor must, within three (3) days, inform the Controller of the requests that may be received from the data subjects...”.

However, it has been established that the Company, in response to the request of the complainant, did

not comply with the aforementioned instructions legitimately given by the controller (see above par. 1). In particular, Medical4All S.r.l. did not provide, except following the invitation to comply issued by this Authority on February 23, 2023, any feedback to the request submitted by the complainant – at least in terms of clarifications regarding the role it held concerning the regulation on the protection of personal data in the case at hand – nor did it promptly convey the aforementioned request to the data controller, so that it could follow up on it within the terms of Article 12, par. 3 of the Regulation.

Therefore, considering the conduct adopted, it follows that Medical4All S.r.l. did not comply with the obligation referred to in Article 28, par. 3, lett. e) of the Regulation – in the terms outlined in the above-mentioned appointment act of June 11, 2018 – to provide assistance to the controller with the technical and organizational measures aimed at “satisfying the obligation of the data controller to follow up on requests for the exercise of the rights of the data subject referred to in Chapter III”. For all the reasons collectively highlighted, such conduct is in contrast with Article 28, par. 3, lett. e) of the Regulation. The violation of the aforementioned provision entails the application of the administrative sanction provided for by Article 83, par. 4, lett. a) of the GDPR.

Taking note of what was stated by the Company during the preliminary investigation, regarding the technical-organizational measures adopted to conform the processing in question to the current regulation on the protection of personal data, as reported above (see above par. 2), the conditions for the adoption of corrective measures referred to in Article 58, par. 2, of the Regulation do not currently exist.

2.2. Violation of Article 157 in relation to what is provided for by Article 166, paragraph 2, of the Code. Without prejudice to what was noted in paragraph 2.1. of this decision, it is also represented that it has been established that the Company failed to provide feedback to the request for information sent by the Authority, pursuant to Article 157 of the Code, on May 2, 2023 (containing the express notice that “in case of non-compliance with this request, the administrative monetary sanction provided for by Article 166, paragraph 2 of the Code will be applied”), despite the aforementioned communication having been duly notified via certified email, the delivery receipt of which is on file.

According to the aforementioned Article 157 of the Code, in fact, “within the powers referred to in Article 58 of the Regulation, and for the performance of its tasks, the Guarantor may request the controller [...] to provide information and to exhibit documents”. In this regard, Article 166, paragraph 2, of the Code establishes that the violation of Article 157 of the Code is subject to the administrative sanction referred to in Article 83, par. 5, of the Regulation.

It follows that the established non-compliance by Medical4All Italia S.r.l. with the invitation to provide information referred to in Article 157 of the Code due to the expiration of the term makes applicable, pursuant to Article 166, paragraph 2, of the Code, the administrative sanction provided for by Article 83, par. 5 of the Regulation.

3. Order of injunction. At the conclusion of the procedure, it has been established that Medical4All Italia S.r.l. has violated Articles 28, par. 3 of the Regulation and 157 of the Code. For the violation of the aforementioned provisions, the application of the administrative monetary sanction provided for by Article 83, par. 4, lett. a) and of Article 85, paragraph 5 of the Regulation, by adopting a penalty order (Article 18 of Law No. 689 of November 24, 1981). The violations established within the terms outlined in the reasoning cannot be considered “minor,” taking into account the nature and severity of the violations and the degree of responsibility, as well as the manner in which the supervisory authority became aware of the violation referred to in Article 28, paragraph 3 of the Regulation (recital 148 of the Regulation). Therefore, in light of the corrective powers granted by Article 58, paragraph 2 of the Regulation, an administrative monetary penalty is imposed pursuant to Article 83 of the Regulation, commensurate with the circumstances of the specific case (Article 58, paragraph 2, letter i) of the Regulation).

In this regard, considering the need to apply paragraph 3 of Article 83 of the Regulation, which states that “if, in relation to the same processing or related processing, a data controller [...] violates, intentionally or negligently, various provisions of this regulation, the total amount of the administrative

monetary penalty shall not exceed the amount specified for the most serious violation,” it is noted that the total amount of the penalty is calculated so as not to exceed the maximum penalty provided for by the same Article 83, paragraph 5.

With reference to the elements listed in Article 83, paragraph 2 of the Regulation for the application of the aforementioned administrative monetary penalty and its quantification, considering that the penalty must “in any case [be] effective, proportionate and dissuasive” (Article 83, paragraph 1 of the Regulation), it is represented that, in this case, the following circumstances have been taken into account:

a) regarding the severity of the violations, the nature of the violations has been acknowledged, particularly concerning the Company’s non-compliance with obligations as a data controller regarding requests for the exercise of the rights of data subjects as per Chapter III (Article 83, paragraph 2, letter a) of the Regulation); at the same time, it has been taken into account in favor of the offender that the conduct in question had a limited duration and concerned a single event and one data subject (Article 83, paragraph 2, letter k) of the Regulation);

b) with reference to the intentional or negligent nature of the violations, the negligent conduct of the Company has been considered, which, although it did not comply with data protection regulations, acted under the erroneous belief—given that it did not have ownership of the processing in question—that it did not need to fulfill any obligations as a data controller in order to respond to the access request of the complainant; regarding the failure to respond to this Authority’s request for information, it is noted that this was due to an organizational misunderstanding (Article 83, paragraph 2, letter b) of the Regulation);

c) concerning the degree of responsibility of the Company, it has been taken into account that the Company, as a data controller, failed to adopt adequate technical and organizational measures to be implemented pursuant to Article 28, paragraph 3, letter e) of the Regulation (Article 83, paragraph 2, letter d) of the Regulation);

d) regarding the degree of cooperation with the Authority, it has been noted that the Company cooperated with the Authority during the proceedings only following the notification of the request for information made by this Authority during the on-site inspections conducted and following them (Article 83, paragraph 2, letter f) of the Regulation), providing useful elements for the definition of the proceedings (Article 83, paragraph 2, letter k) of the Regulation);

e) it has also been noted that the failure to respond to the Authority’s request for information aggravated the proceedings, both in terms of time and costs (Article 83, paragraph 2, letter k) of the Regulation);

f) regarding the adoption of measures to mitigate or eliminate the consequences of the violations, it has been positively considered that the Company has stated that it has implemented some technical-organizational measures regarding the protection of personal data, aimed at ensuring a more appropriate management of user requests, in accordance with current regulations (Article 83, paragraph 2, letter c) of the Regulation);

g) finally, it has been taken into account the absence of previous violations committed by the Company or previous measures pursuant to Article 58 of the Regulation (Article 83, paragraph 2, letter e) of the Regulation).

It is also believed that the economic conditions of the offender are relevant in this case, considering the aforementioned principles of effectiveness, proportionality, and dissuasiveness to which the Authority must adhere in determining the amount of the penalty (Article 83, paragraph 1 of the Regulation). Lastly, the amount of penalties imposed by the Authority in similar cases is also considered.

In light of all the elements outlined above, evaluated as a whole, it is deemed appropriate, in this specific case, to impose on Medical4All Italia S.r.l. an administrative penalty of payment of an amount equal to €15,000.00 (fifteen thousand).

In this context, also considering the type of violation established, which involved non-compliance with specific obligations of the data controller regarding the rights of data subjects (Articles 28, paragraph 3, letter e) of the Regulation) and the consequences arising from the same against the claimant (first of all, the failure to respond, within the terms of Articles 12 et seq. of the Regulation, to the request for access to information concerning him), it is deemed that, pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Garante Regulation no. 1/2019, the publication of this provision on the Garante's website should proceed.

It is finally noted that the conditions referred to in Article 17 of Regulation no. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers assigned to the Garante, are met.

ALL OF THE ABOVE CONSIDERED, THE Garante

pursuant to Articles 57, paragraph 1, letter f) and 83 of the Regulation, finds the unlawfulness of the processing carried out by Medical4All Italia S.r.l., represented by its legal representative, with registered office in Milan, VAT number 03548040967, as stated in the reasoning, for the violation of Article 28, paragraph 3, letter e) of the Regulation and Article 157 of the Code;

#### ORDERS

pursuant to Article 58, paragraph 2, letter i) of the Regulation to the same Medical4All Italia S.r.l. to pay the sum of €15,000.00 (fifteen thousand) as an administrative pecuniary sanction for the violation indicated in the reasoning;

#### COMMANDS

therefore Medical4All Italia S.r.l. to pay the sum of €15,000.00 (fifteen thousand), according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of subsequent enforcement actions pursuant to Article 27 of Law no. 689/1981. It is represented that pursuant to Article 166, paragraph 8 of the Code, the offender retains the option to settle the dispute by paying – always according to the methods indicated in the annex – an amount equal to half of the imposed sanction within the term referred to in Article 10, paragraph 3, of Legislative Decree no. 150 of September 1, 2011, provided for the submission of the appeal as indicated below.

#### DISPOSES

pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Garante Regulation no. 1/2019, the publication of this provision on the Garante's website and considers that the conditions referred to in Article 17 of Regulation no. 1/2019 are met.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree no. 150 of September 1, 2011, an appeal against this provision may be filed before the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, September 12, 2024

THE PRESIDENT

Stanzione

THE REPORTER

Ghiglia

THE SECRETARY GENERAL

Mattei